Universiteit van Amsterdam
Amsterdam Business School

Cybersecurity Governance, Compliance & Regulation

Prof.dr. Martijn Dekker

Agenda

- Short lookback to last week's class
- Cybersecurity governance:
  - Role of the board
  - Role of management
  - Role of Operations: IT & security functions
- Three Lines Model (management, risk/compliance, audit)
- Regulatory landscape (high level):
  - GDPR (focus on security & breach notification)
  - NIS2
  - Industry regulations (finance, healthcare)
- Compliance vs security
- Reporting cyber risks to executives

Odido case

What we care about: Understand CIA Ratings (for data)

Each component of CIA refers to:

Confidentiality (C) – Ensures only authorized access to data.

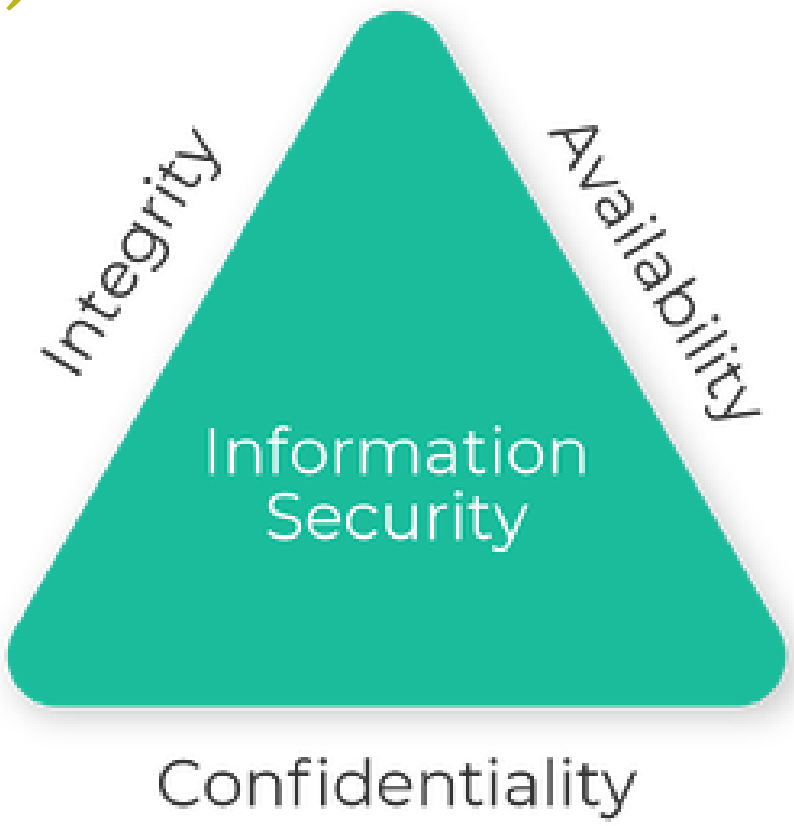
- High: Very sensitive data; a breach could cause severe harm (e.g., patient medical records).
- Medium: Moderately sensitive; minor impact if disclosed.
- Low: Public or non-sensitive data.

Integrity (I) – Ensures data is accurate and unaltered.

- High: Incorrect data could cause major harm (e.g., financial transactions).
- Medium: Errors are undesirable but manageable.
- Low: Minor errors don't cause significant issues.

Availability (A) – Ensures data or services are accessible when needed.

- High: Outages are critical (e.g., emergency systems).
- Medium: Downtime is inconvenient but manageable.
- Low: Outages are tolerable.



What we worry about? Knowing threats

Threat Intelligence Lifecycle

1 Planning

Defining what the goal is and crafting questions to guide the collection of information..

2 Collection

Data is gathered from a variety of internal and external sources.

3 Processing

Deduplication, enrichment, and normalization of the data to ensure it's ready for analysis.

4 Analysis

Identifying patterns, correlating indicators, and understanding the context behind the data.

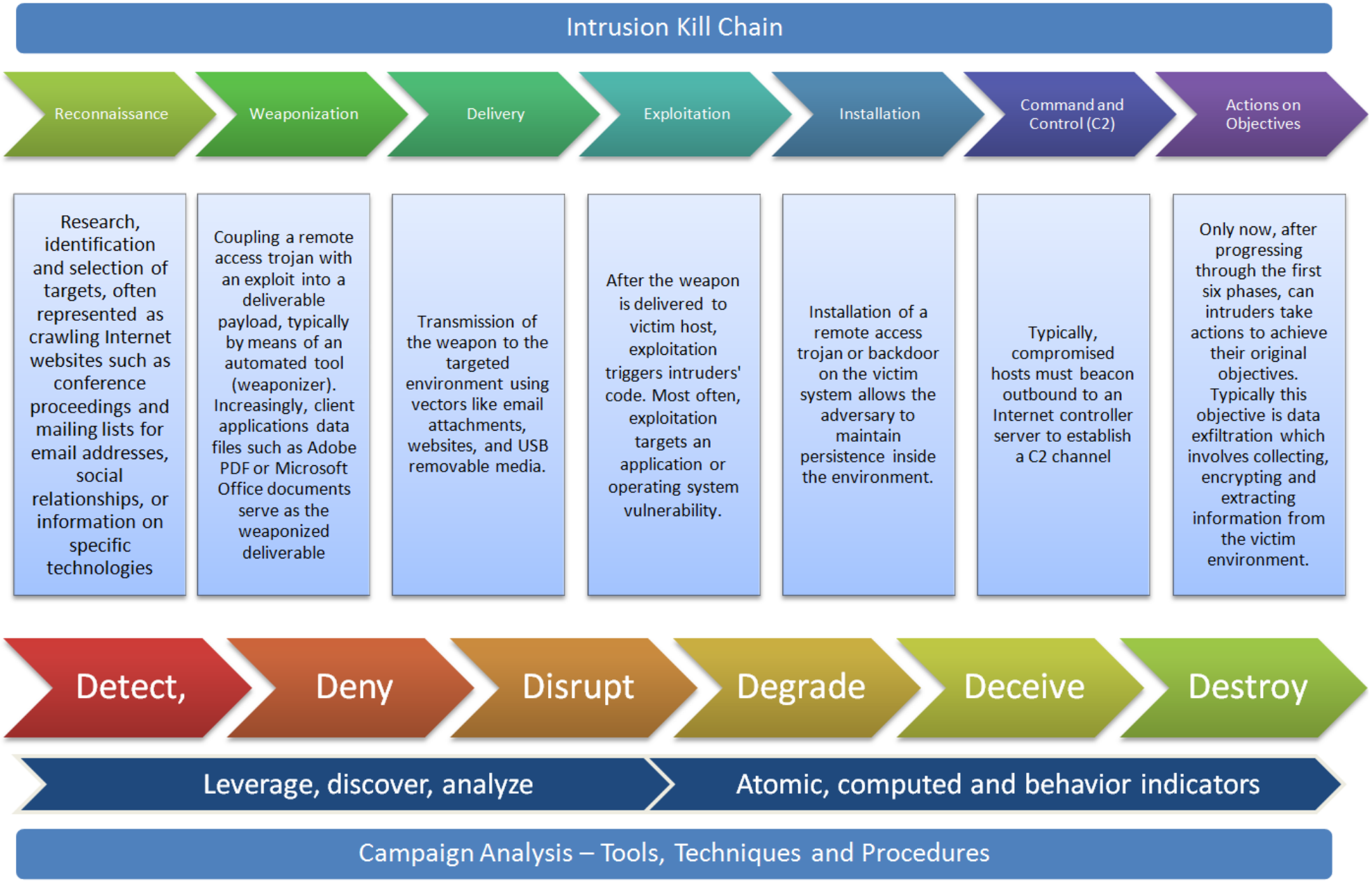
5 Dissemination

Presented in a format that is actionable and accessible to the right teams.

6 Feedback

Gathering feedback on the effectiveness of the intelligence closes the loop in the lifecycle.

Balbix


Intrusion Kill Chain
Reconnaissance
Weaponization
Delivery
Exploitation
Installation
Command and Control (C2)
Actions on Objectives
Research, identification and selection of targets, often represented as crawling Internet websites such as conference proceedings and mailing lists for email addresses, social relationships, or information on specific technologies
Coupling a remote access trojan with an exploit into a deliverable payload, typically by means of an automated tool (weaponizer). Increasingly, client applications data files such as Adobe PDF or Microsoft Office documents serve as the weaponized deliverable
Transmission of the weapon to the targeted environment using vectors like email attachments, websites, and USB removable media.
After the weapon is delivered to victim host, exploitation triggers intruders' code. Most often, exploitation targets an application or operating system vulnerability.
Installation of a remote access trojan or backdoor on the victim system allows the adversary to maintain persistence inside the environment.
Typically, compromised hosts must beacon outbound to an Internet controller server to establish a C2 channel
Only now, after progressing through the first six phases, can intruders take actions to achieve their original objectives. Typically this objective is data exfiltration which involves collecting, encrypting and extracting information from the victim environment.
Detect,
Deny
Disrupt
Degrade
Deceive
Destroy
Leverage, discover, analyze
Atomic, computed and behavior indicators
Campaign Analysis – Tools, Techniques and Procedures

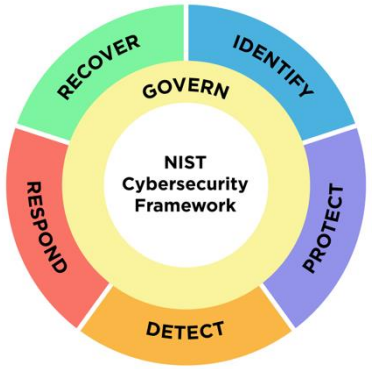
Voettekst

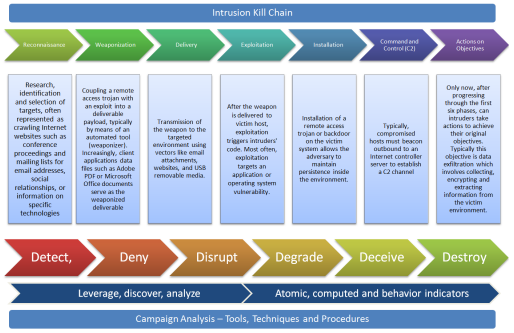
NIST Cybersecurity Framework

Capability	Description
Identify	What processes and assets need protection?
Protect	Implement appropriate safeguards to ensure protection of the enterprise's assets
Detect	Implement appropriate mechanisms to identify the occurrence of cybersecurity incidents
Respond	Develop techniques to contain the impacts of cybersecurity events
Recover	Implement the appropriate processes to restore capabilities and services impaired due to cybersecurity events

Controls, Threats and Risk Appetite Should Fit at all times

- (executive). Managers need to ensure that the implemented control framework is appropriate for the organization and operating withing defined risk appetite. This is a continuous activity of preparation, assessment, testing, executing controls, and adjusting.





Human Behaviour

- We spent much time on technical and procedural controls to mitigate cyber risks
- Standards bodies and regulatory frameworks increasingly recognize that technical controls alone are insufficient for managing cybersecurity risk.
- Human error, social engineering, misunderstanding of procedures, and organizational culture are repeatedly identified as si gnificantcontributing factors in security incidents. People interact directly with organizational assets and controls: they create and handle information, configure systems, approve access, and respond to abnormal situations.
- Through these interactions, individuals can either strengthen security or unintentionally undermine it. As a result, humans function simultaneously as assets, sources of risk, and active security controls within the organization.
- From a risk management perspective, the human element is therefore a central driver of both the likelihood and impact of cybersecurity incidents. Threats such as phishing, credential compromise, insider misuse, and accidental data disclosure explicitly exploit human behavior rather than technical weaknesses.
- At the same time, humans are not the weakest link: humans often prevent incidents or stop them before they become big. Ignoring these factors leads to incomplete risk assessments and an over reliance on technical defenses.
- **Clear policies and standards are necessary to support humans in cybersecurity**
- This week we will discuss more the governance and organization

Governance and Policy

- **Governance** is the overall complex system or framework of processes, functions, structures, rules, laws and norms born out of the relationships, interactions, power dynamics and communication within an organized group of individuals.
- **Policy** is a deliberate system of guidelines to guide decisions and achieve rational outcomes. A policy is a statement of intent and is implemented as a procedure or protocol. Policies are generally adopted by a governance body within an organization.

- Many causes of incidents show that these incidents often stem from systemic gaps in governance, for example lack of policy adherence. These gaps are characterized by:
  - Unclear accountability,
  - insufficient oversight,
  - misaligned incentives,
  - and poorly defined or communicated risk tolerance.

- When governance structures fail, even the most sophisticated technical defenses can be undermined.

Example: Equifax

- An Equifax internal audit in **2015** revealed a significant backlog of unresolved vulnerabilities. The audit found that Equifax was not adhering to its own patching schedules, IT staff lacked a comprehensive asset inventory, and the company did not prioritize patches based on the criticality of IT assets. Additionally, the patching process relied on an honour system, without strict enforcement.
- A key security patch for Apache Struts, a web application framework, was released on **March 7, 2017**, after a critical security vulnerability was identified, and all users of the framework were urged to update immediately. Equifax had not patched in **May**, and the vulnerability was exploited.
- The report outlined actions to improve security measures, but by the time of the breach (two years later), many had not been implemented.
- What governance issues do you see?
  - Non-adherence to its own policies (patching),
  - Lack of asset inventory (so no CIA rated asset administration),
  - Lack of risk-based / criticality-based prioritization,
  - No enforcement of patching execution,
  - No follow-up on identified security improvements.

Example: Target

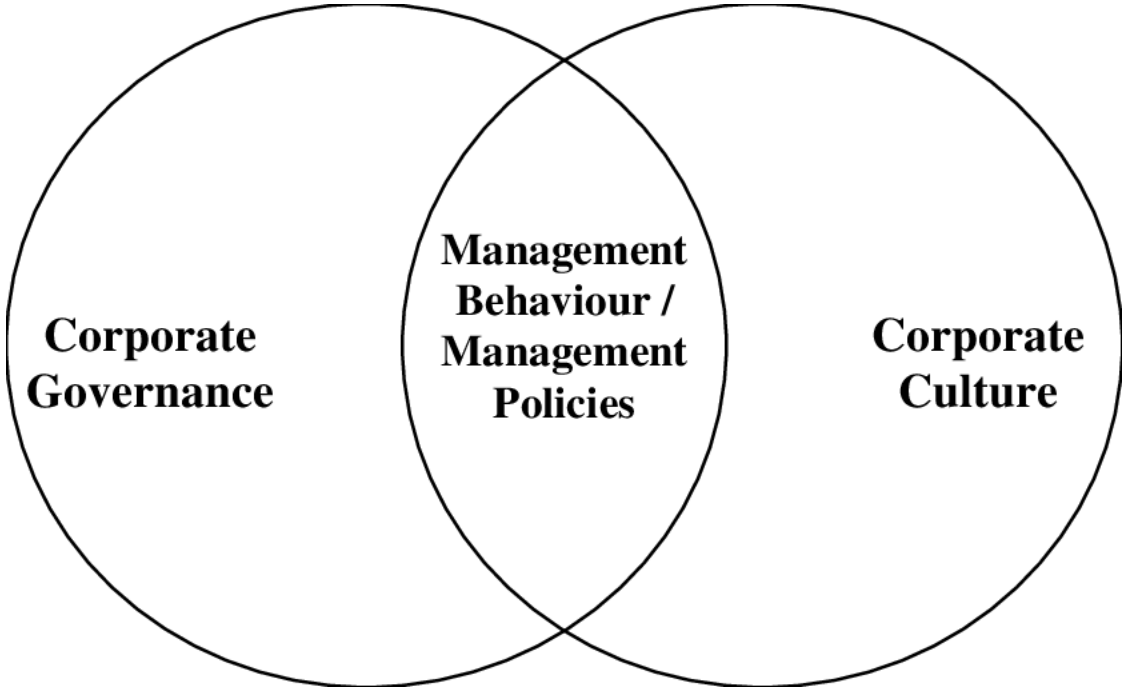
- Between 27 November and 15 December 2013, Target's American brick-and-mortar stores experienced a data hack. Around 40 million customers' credit and debit cards became susceptible to fraud after malware was introduced into the POS system in over 1,800 stores. The data breach of Target's customer information saw a direct impact on the company's profit, which fell 46 percent in the fourth quarter of 2013.
- Six months prior the company began installing a $1.6 million cyber security system. Target had a team of security specialists to monitor its computers constantly. Nonetheless, the supply chain attack circumvented these security measures.
- It is believed that cyber criminals infiltrated a third-party supplier to gain access to Target's main data network. Although not officially confirmed, investigation officials suspect that the hackers first broke into Target's network on 15 November 2013 using passcode credentials stolen from Fazio Mechanical Services, a Pennsylvania-based provider of HVAC systems.
  - Lack of governance and oversight of third-parties,
  - Incomplete risk assessment and incorrect security investments,
  - Fragmented processes, siloed security approaches.

The use of Governance – boardlevel involvement

- Governance provides the necessary framework to
  - define the cybersecurity objectives,
  - assign accountability, and monitor performance.
- It aligns cybersecurity initiatives with business goals, ensuring that security is not a technical concern but a strategic business priority.
- cybersecurity governance answers several fundamental questions:
  - Who is accountable for managing cyber risk?
    Clearly defined roles and responsibilities ensure that decision-makers are held accountable for cybersecurity outcomes, preventing ambiguity during incidents.
  - How much risk is acceptable?
    Organizations need a well-articulated risk tolerance to guide their decisions on what level of exposure is permissible in pursuit of business objectives. Without this, an organization may either overinvest in cybersecurity controls, diverting resources away from other priorities, or underinvest, leaving critical systems vulnerable.
  - How do we know whether our controls are effective?
    Performance monitoring and auditing mechanisms, are essential to assess whether security measures are functioning as intended and whether they are adequate given the constantly evolving threat landscape.

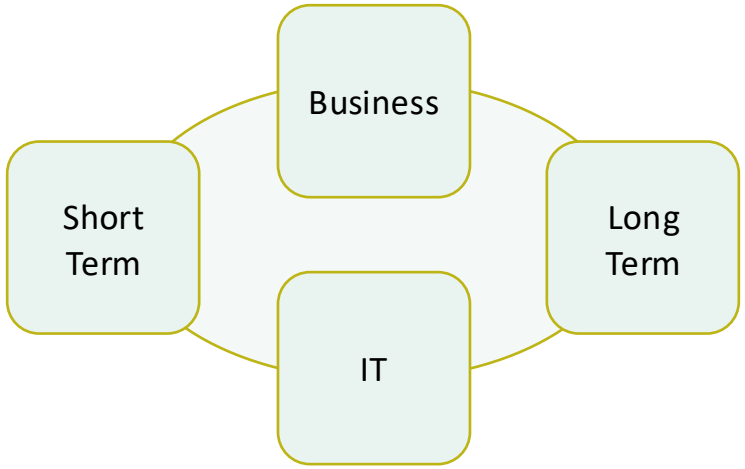
Culture

- In essence, cybersecurity governance is not just about setting rules and policies, but about creating a culture of security where accountability, transparency, and continuous improvement are at the forefront.



Governance: Direction and Oversight.

- governance is primarily concerned with setting the overall direction and providing oversight.
- Governance is exercised by senior executives, boards of directors, and other decision-makers who are responsible for establishing the strategic framework that guides an organization's cybersecurity initiatives.
- includes establishing the organization's risk appetite—the level of risk the organization is willing to accept in pursuit of its business objectives—and ensuring that cybersecurity practices are aligned with the organization's broader goals.
- It is also responsible for approving and reviewing policies, assigning accountability for cybersecurity outcomes, and ensuring compliance with regulatory requirements.
- Effective governance ensures that cybersecurity initiatives support the long-term objectives of the organization, not just the immediate technical needs.



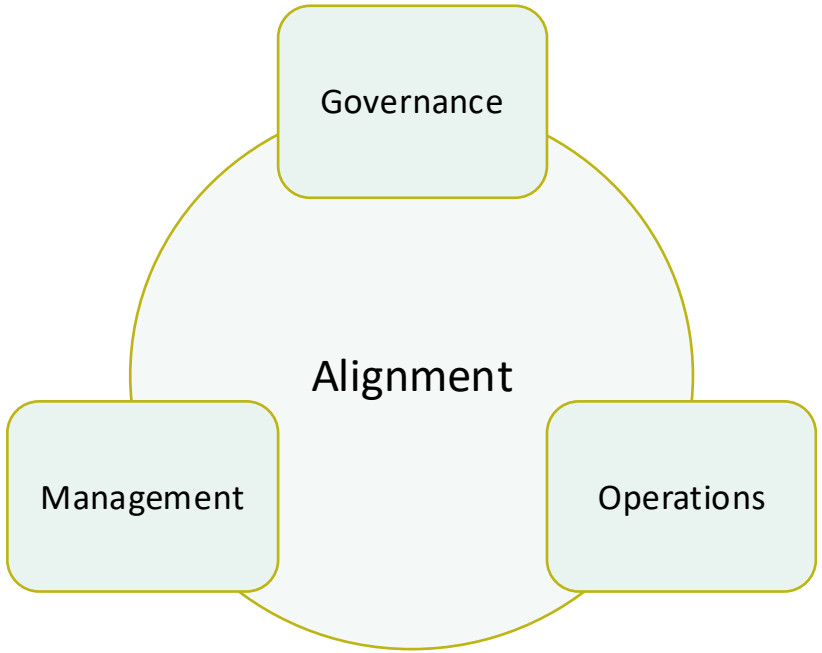
Management: Translating Strategy into Action.

- Management is responsible for translating these high-level goals into concrete plans and actions.
- Managers play a crucial role in taking the directives established by governance and turning them into actionable strategies. They are responsible for
  - allocating resources,
  - designing cybersecurity programs,
  - setting priorities, and
  - coordinating activities across various teams.
- It ensures that cybersecurity efforts are focused on the right areas, based on the organization's risk tolerance and strategic objectives.
- It plays a key role in aligning cybersecurity activities with other business functions. This includes ensuring that employees are trained on security protocols, that there are clear processes for incident response, and that security is embedded into business operations across departments.
- It makes sure that strategic intent is linked to day-to-day activities.

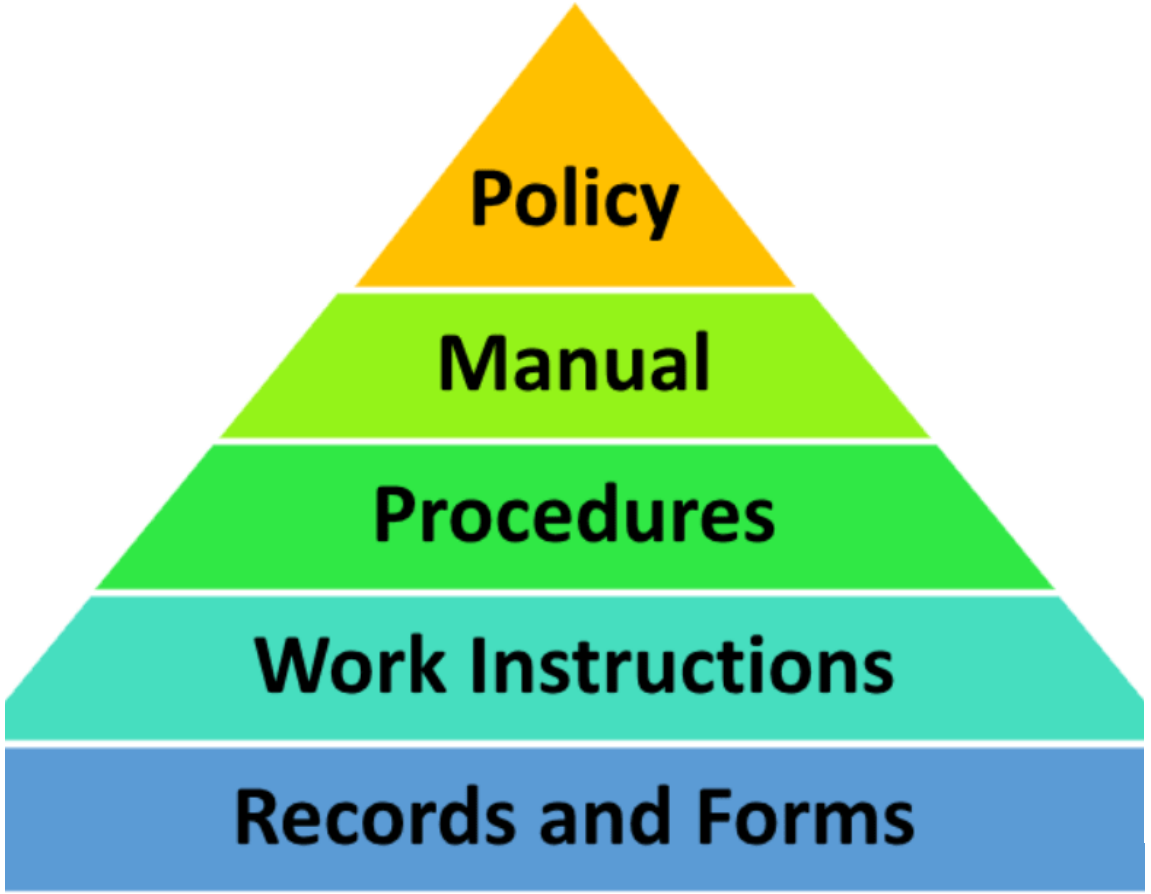
Operations: Execution and Monitoring.

- operations are the day-to-day activities that ensure the security controls, monitoring, and response mechanisms are actively functioning.
- The operations team is responsible for implementing and executing the cybersecurity policies and procedures designed by management. This includes
  - the ongoing tasks of monitoring systems for vulnerabilities,
  - responding to security incidents,
  - conducting threat assessments, and
  - maintaining security controls such as firewalls, intrusion detection systems, and endpoint protections.
- While governance sets the strategic vision and management creates the plan, operations ensuring that security measures are continuously applied and refined.
- The otherway around, Operations need guidance from management to prioritize tasks based on the organization's risk profile, and they need clear policies from governance to understand the acceptable level of risk and the boundaries within which they must operate.

Alignment Is Key.



Policies and Standards: Governance controls



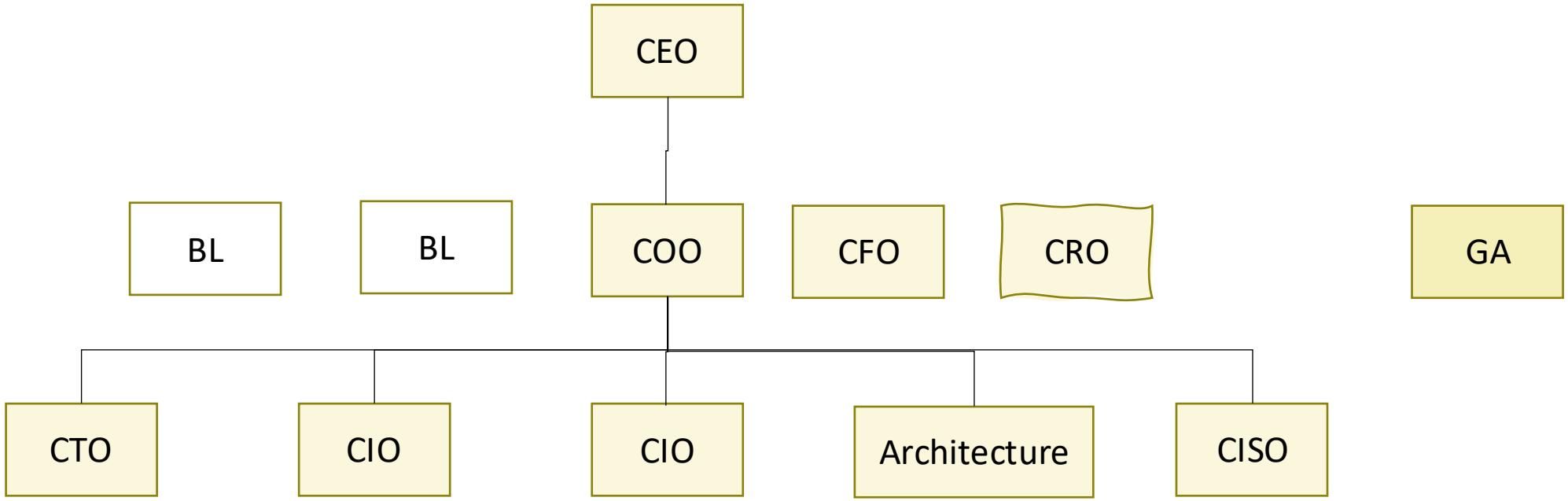
The Interrelationship Between Policy, Standard, and Procedure.

The relationship between policy, standard, and procedure is hierarchical and interdependent, with each element serving a distinct function in the broader governance framework. In summary:

- Policy defines the "what" and the "why"—it articulates the organizational intent, sets priorities, and establishes high-level objectives for cybersecurity,
- Standard defines the "what" in operational terms—it translates policy into specific, enforceable requirements that must be followed,
- Procedure defines the "how"—it translates the standards into actionable steps that individuals or teams must follow to ensure compliance.

This hierarchical structure is necessary to ensure that cybersecurity governance remains coherent, transparent, and actionable. When misaligned, these components can result in ambiguity, inefficiency, or even failure to implement effective cybersecurity controls.

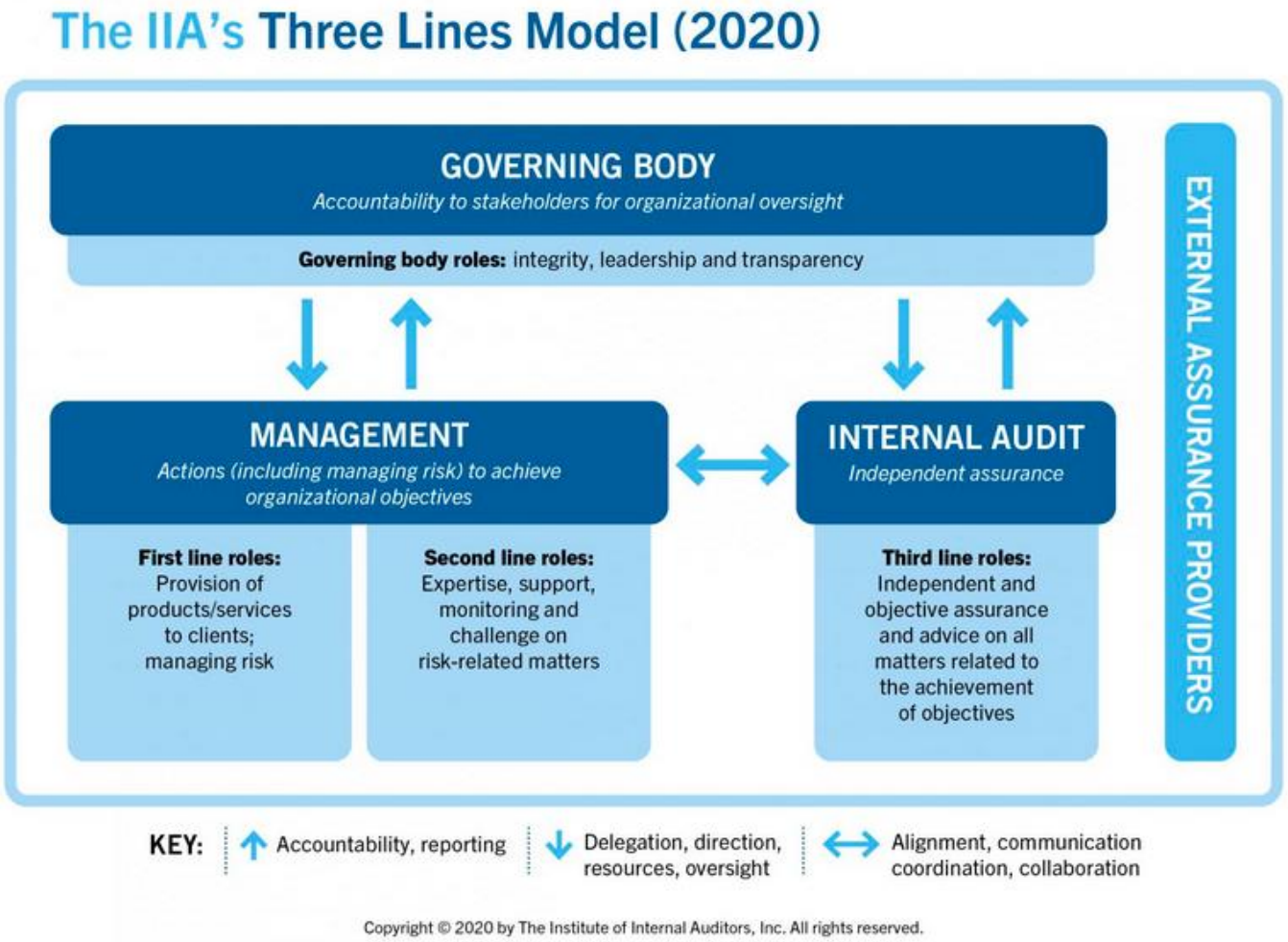
How is IT organized?
A typical IT org chart (for larger organizations)



CEO: Chief Executive Officer
BL: Business Line
COO: Chief Operations Officer
CFO: Chief Financial Officer
CRO: Chief Risk Officer

CTO: Chief Technology Officer
CIO: Chief Information Officer
CISO: Chief Information Security Officer
GA: Group Audit

The 3 lines of defence *updated*



©2021

Financial reporting
Risk and internal control
Internal auditing
External auditing
Governance & Compliance
Audit committee

Three ways to organise IT supervision

- Appoint a specialist as non-executive or member of supervisory board
- Include IT risk supervision in the Audit Committee
- Implement a special IT Committee, next to the Audit Committee

How is it organised in your organisation?

Cybersecurity Regulation and Liability

NIS1/NIS2:

New requirements for governance and control. Risks of sanctions and “hoofdelijke aansprakelijkheid”

DORA:

New requirements for cyber resilience for the financial sector

GDPR:

Sanctions and liability, requirements for data protection of data of EU citizens

NIS2 directive, in force since 1-1-2023
Applicable in NL from 11-2024

CHAPTER IV

CYBERSECURITY RISK-MANAGEMENT MEASURES AND REPORTING OBLIGATIONS

Article 20

Governance

1. Member States shall ensure that the management bodies of essential and important entities approve the cybersecurity risk-management measures taken by those entities in order to comply with Article 21, oversee its implementation and can be held liable for infringements by the entities of that Article.

The application of this paragraph shall be without prejudice to national law as regards the liability rules applicable to public institutions, as well as the liability of public servants and elected or appointed officials.

Why has DORA been defined?

- Credit crunch (2009-2014); Stress testing (financial focus over operational focus);
- Cybercrime activities heavily increased;
- Digitalization → Increased dependency on IT supply chain;
- Lack of uniform rule set across EU countries wrt digital operational resilience;
- Lack of sufficient means for financial authorities for effective supervision;
- Being part of a broader pack of Digitalization acts (ref. Digital Services Act, AI Act, Digital Markets Act, etc.);
- DORA specific for the financial sector. NIS2 for all other sectors.

- Multiple reasons have led to DORA development
- DORA is a logical and desirable set of rules to maintain and improve digital services to our customers.

Key components – 5 pillars

KEY OBLIGATIONS

Pillar 1 - ICT Risk Management
Internal controls and governance structure ICT Risk system and tools

Pillar 2 - Classification and Reporting of ICT related incidents
Reporting to regulators based on thresholds

Pillar 3 - ICT Third Party Risk Management
Lifecycle based supervision of ICT third parties

Pillar 4 - Digital Operational Resilience Testing
Risk based testing for preparedness and weakness identification

Pillar 5 - Information Sharing between Financial Entities
Exchange of cyber threat information and intelligence

- Five pillars are focus areas of DORA level 1.
- More details in the Regulatory/Implementing Technical Standards(RTS/ITS).
- Some RTS/ITS published late: July 2024.

DORA focusses on several risk types, not only Cyber risk

Cyber risk
- Ransomware
- Identity theft
- (un)intentional deletion of data

Natural disasters
- Flooding
- Fire

Supplier risk
- Bankruptcy
- Compliancy violations

RISK TYPES

Gen AI risk
- Inaccuracy, Instability and errors
- Algorithmic aversion, overreliance, misalignment

IT Operations / Continuity risk
- Network failure
- Disk full / Malfunction of system
- Failed IT change
- Misconfiguration of IT system

Criminal activities
- Fraud
- Theft

- Operational Resilience is about more than only managing Cyber risk.

Nieuwe corporate governance code

- https://www.mccg.nl/actueel/nieuws/2022/12/20/publicatie-van-de-geactualiseerde-code-monitoring-rapport-en-slotdocument

Onze samenleving ondergaat een transformatie op zowel het gebied van duurzaamheid als digitalisering. Om deze transformatie in goede banen te leiden dienen bij het bestuur en bij de raad van commissarissen diepgaande kennis en ervaring aanwezig te zijn om deze dimensies in de onderneming op te kunnen bouwen en toe te zien op de kwaliteit ervan. Duurzaamheid en digitalisering zijn geen aparte of ondersteunende processen, maar raken de kern van de strategie en de bedrijfsvoering van de onderneming. Vennootschappen zijn vrij in de keuze om al dan niet een specifieke digitaliserings- en duurzaamheidscommissaris en/of een specifieke bestuurder met kennis op dit vlak te benoemen. Een dergelijke benoeming ontslaat de overige bestuurders en commissarissen niet van nauwe betrokkenheid bij deze thema's. Omdat de genoemde transformaties zo ingrijpend zijn, behoort het tot de taak van iedere bestuurder en commissaris om de afwegingen hieromtrent te maken. Het is van belang om hier aandacht aan te geven bij zowel de samenstelling van het bestuur en de raad van commissarissen, alsook bij de periodieke opleiding en educatie ingevolge best practice bepaling 2.4.6.

Beyond liability

- The intention of all these systems, governances and regulations is to ensure a proper conversation about cybersecurity on all levels of management in an organisation
- Key elements for this are:
  - Clear roles & responsibilities,
  - Good data quality for “what we care about” (the assets), “what we worry about” (the threats)
  - And: good insights into operational performance and effectiveness of the chosen controls!

- If you are a CISO, what type of dialogue would you like to have with senior management?
- If you are a board member, and you feel the DORA liability, what type of dialogue would you like to have with your CISO?

Conclusions

- Cybersecurity is a multidisciplinary topic,
- It is a topic that requires management attention and organisation across the whole organisation,
- Doing it right or doing it wrong, impacts all stakeholders of an organisation: customers, shareholders, partners and suppliers, employees, society etc,
- Advanced models and standards for how to organise security exist:
  - Control frameworks like NIST CSF and ISO 27k,
  - Lines of defence and codes for corporate governance for governance, policy and operations,
  - Risk management and Threat intel processes for aligning security efforts with business outcomes and resource allocations
  - Regulations like DORA, NIS2 and GDPR to ensure consistency across industries and geographies

- The role of Auditing will be the topic for the next two lectures (by prof.dr. Edo Roos Lindgreen).

Universiteit van Amsterdam
Amsterdam Business School

Cybersecurity Governance, Compliance & Regulation

Prof.dr. Martijn Dekker